

Unlocking doors from half a continent away



Loudmouth
security

Offensive. About security.

- 12+ years in Offensive application and network security
- Led and contributed to numerous Red Team engagements
- DEF CON 26 Black Badge holder (part of 3-person team)
- Former Lead, Pros versus Joes (PvJ) Red Cell
- Founding Partner & Hacker @ Loudmouth Security
- Based out of Ottawa, Ontario

\$ whoami

Trevor Stevado

**GWAPT, GPEN, OSCP, Certified
SCADA Security Analyst**

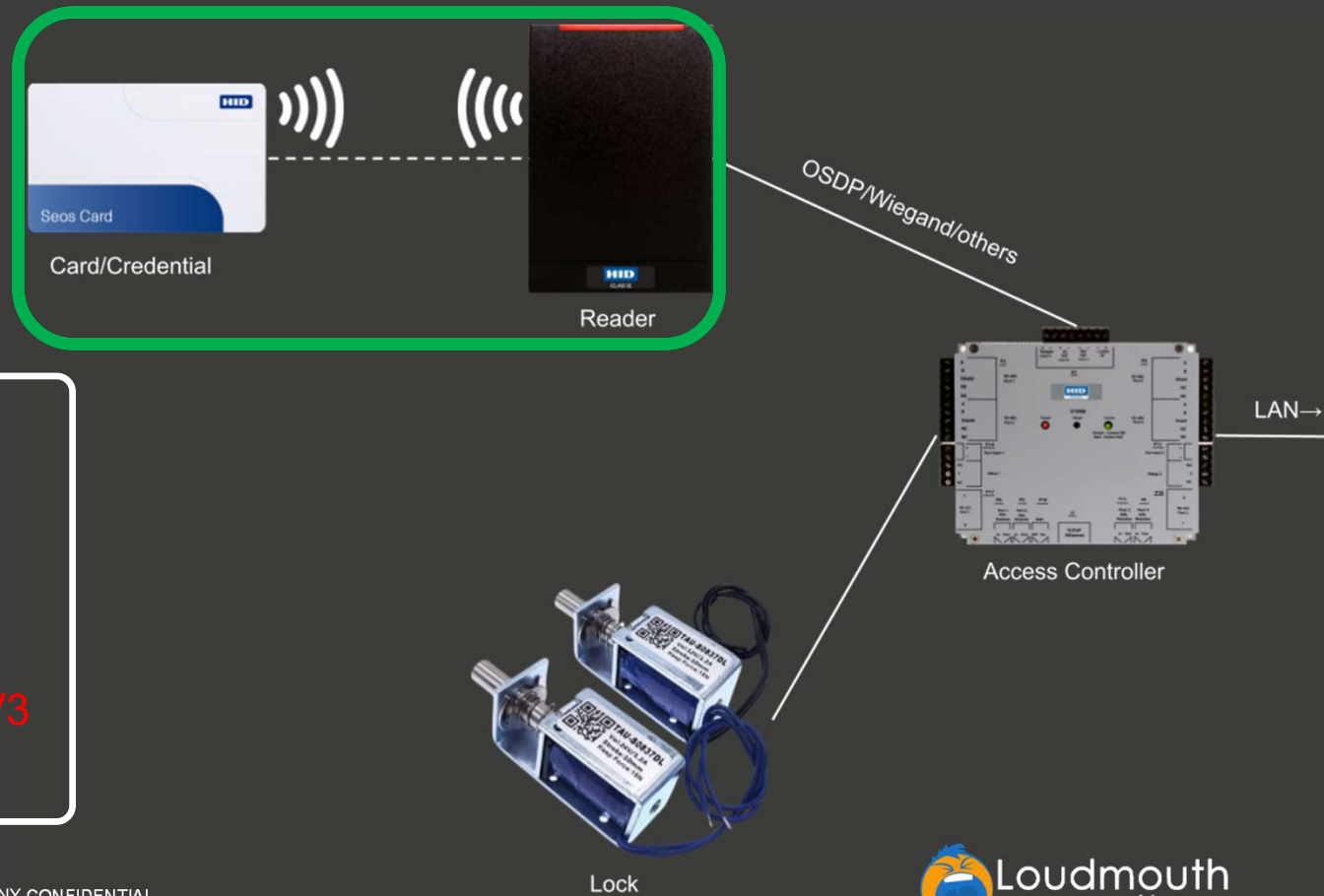
whoami Sam Haskins

OSSD
Hon.BCS (in progress)

- Current CS student at Carleton University in the Computer and Internet Security Stream
- Hacking things since I was 12
- Two CVEs (ages 16 and 19)
- Second year @ DEFCON
- Hacker @ Loudmouth Security
- Based out of Ottawa, Ontario

Background

ATTACK >>>



Some technologies:

- Prox
- Indala
- iClass
- Mifare Classic
- Mifare DESFire EV1/EV2/EV3
- Seos

Problem statement:

- Assert the physical presence of an original credential at time of authentication.

Some categories of attacks...

Card-cloning attack (“original”)

Given a period of access to a card, create some sort of object that can stand in for the card at time of authentication.

- **Downgrade attack**

Read the UID from a credential using an (attacker-controlled) legitimate reader and write it onto a credential using a “less secure” technology.

Problem statement:

- Assert the physical presence of an original credential at time of authentication.

Some categories of attacks...

Replay attack (“at time of authentication”)

Given the full sequence of messages exchanged between a card and reader during one or more successful authentications, create some sort of object that can stand in for the card at time of authentication.

Problem statement:

- Assert the physical presence of an original credential at time of authentication.

Some categories of attacks...

Relay attack (“physical presence”)

Authenticate to a reader with a card located some distance away. (Typically) Assume only brief access to card & reader.

<<< we did this one

History

(Probably just a review for some of you)

HID Prox

- Before 1991—one of the earliest contactless technologies
- Low-frequency; operates at 125 kHz
- Shouts its unique ID in plaintext to anyone listening (at least read range is only a few meters, max)
 - Worse than magstripes 😊
- You can buy a card cloner on Amazon for $\approx$ \$40
- Bishop Fox DEF CON 21 – Tastic RFID Thief →

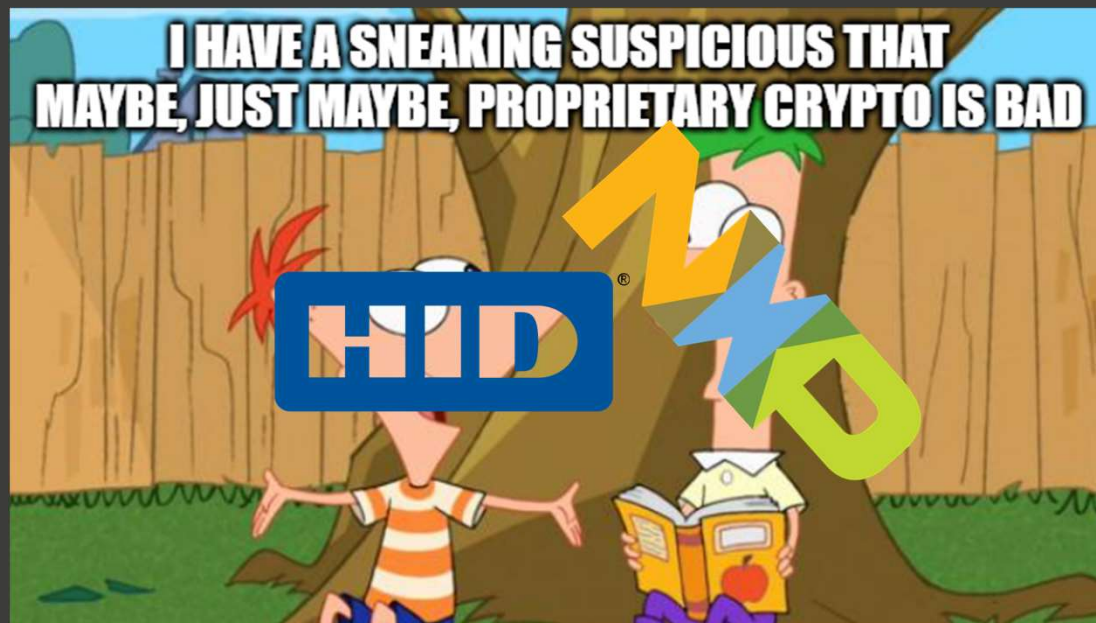


HID iClass (or iCLASS)

- Circa 2002
- High-frequency; operates at 13.56 MHz
- Designed to protect against card-cloning and replay attacks
- Messages sent between the card and reader are authenticated with a shared key
 - A proprietary cipher was used to build a MAC (Message Authentication Code) algorithm
- Cipher was reverse-engineered and broken by Garcia et al
 - Worldwide standard key recovered using this work
 - Facility-specific elite-keys can be recovered by interacting with a reader

Mifare Classic

- Circa 1994
- High-frequency; operates at 13.56 MHz
- Intended for a wide variety of applications (less common for access control)
 - To use with access control, a unique ID is wrapped in a Secure Identity Object (SIO) and provisioned on the card (before receipt by deploying party)
- Designed to protect against card-cloning and replay attacks
- Uses the proprietary Crypto-1 cipher to protect card data
- Cipher was reverse-engineered and broken by a team at Radboud University  between 2006-09
 - Card cloning now trivial with Proxmark



HID Seos (c.2012) and NXP Mifare DESFire (c.2006) use standardized, battle-hardened ciphers (and makes sure to feature that quite prominently in their datasheets)

No public technique to clone Seos or DESFire (any version)...even after 17 years.

Secure Messaging

EN 14890-1 and 7816 aligned using AES/2TDEA algorithm

Mutual Authentication

AES-128/2TDEA cryptographic algorithms for data protection P800-56A (for session key derivation)
Mutual authentication protocol with generation of diversified session key to protect each card session (using secure messaging).

Leverages AES-128 based SIO data model and security.

The main characteristics of this device are denoted by its name “DESFire”: DES indicates the high level of security using a 3DES or AES hardware cryptographic engine for enciphering transmission data and Fire indicates its outstanding position as a fast, innovative, reliable and secure IC in the contactless proximity transponder market.

- Hardware DES using 56/112/168 bit keys featuring key version, data authenticity by 8 byte CMAC
- Hardware AES using 128-bit keys featuring key version, data authenticity by 8 byte CMAC
- Data encryption on RF-channel
- Authentication on application level

Downgrade attacks

- Downgrade attacks are *often* possible on real Seos/DESFire deployments
- Some techniques to prevent them
 - Elite keying
 - Configure readers to only accept Seos/DESFire
- Different readers can have different configurations
 - Loading bay reader could be Prox/Seos, but vault is Seos only
 - Attacker wouldn't have these details; must "assume the worst"
- Security-sensitive deployments with high value in compromise are resistant/impervious to downgrade attacks
- **Downgrade attacks are ineffective against hardened targets**

**If you can't break
the crypto...**

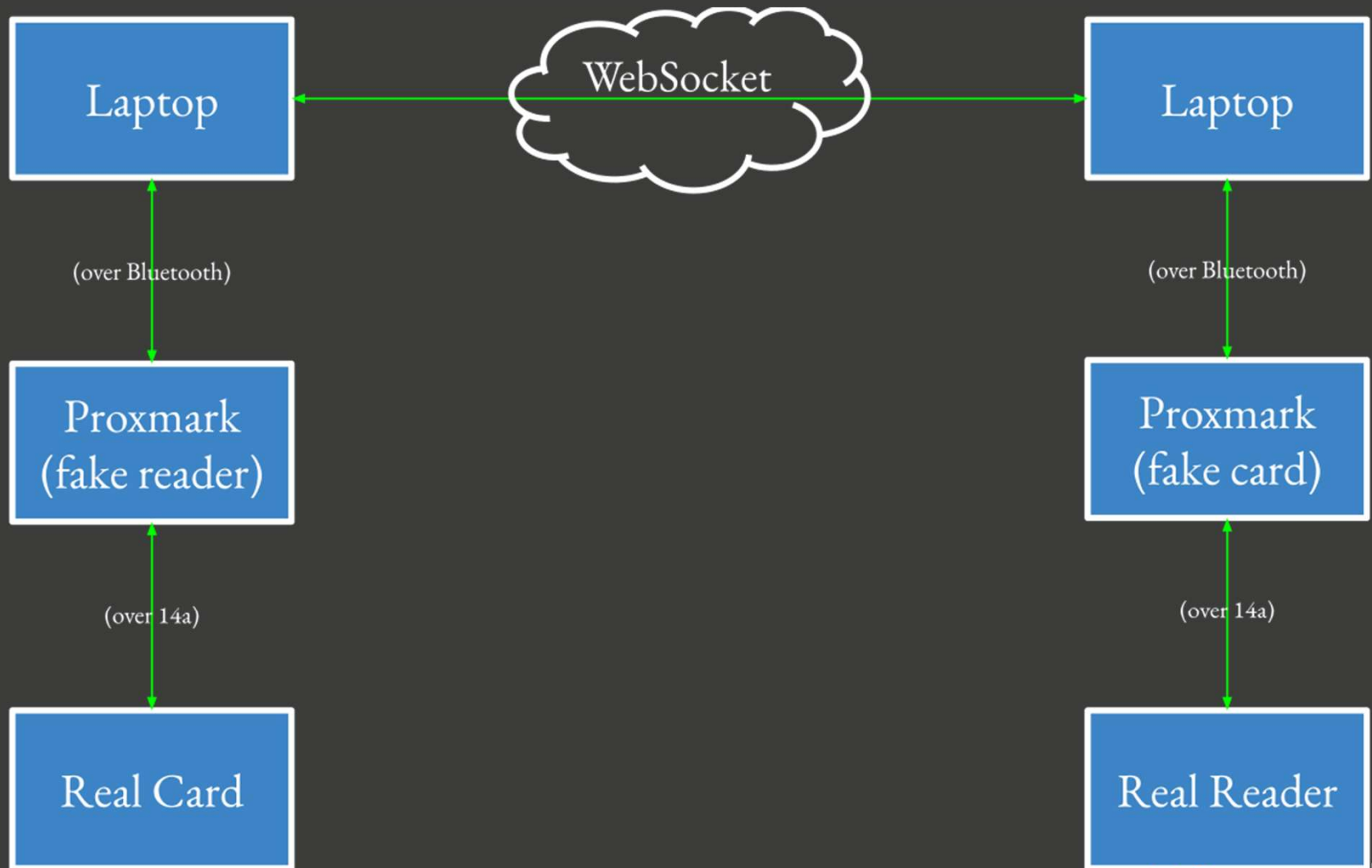
**...go for a relay
attack instead!**

Relay Attack Scenario



A threat actor would like to gain access to a secure facility protected by Seos. Agent A sidles up next to an employee on public transit and covertly holds a relay device close to the employee's pass. Concurrently, Agent B approaches the secure facility and briefly presents another relay device, connected to the first, to the reader. The reader flashes green, and the door opens.

This is totally possible today!



Slide 17

TS0 I think we simplify this image to just show a single arrow between card and proxmark. We can show this again after we explain 14a and talk about how we handle some of that locally

Trevor Stevado, 2023-07-25T15:55:00.157

TS0 0 [@Sam Haskins]

Trevor Stevado, 2023-07-25T15:55:18.382

SH0 1 Resolved

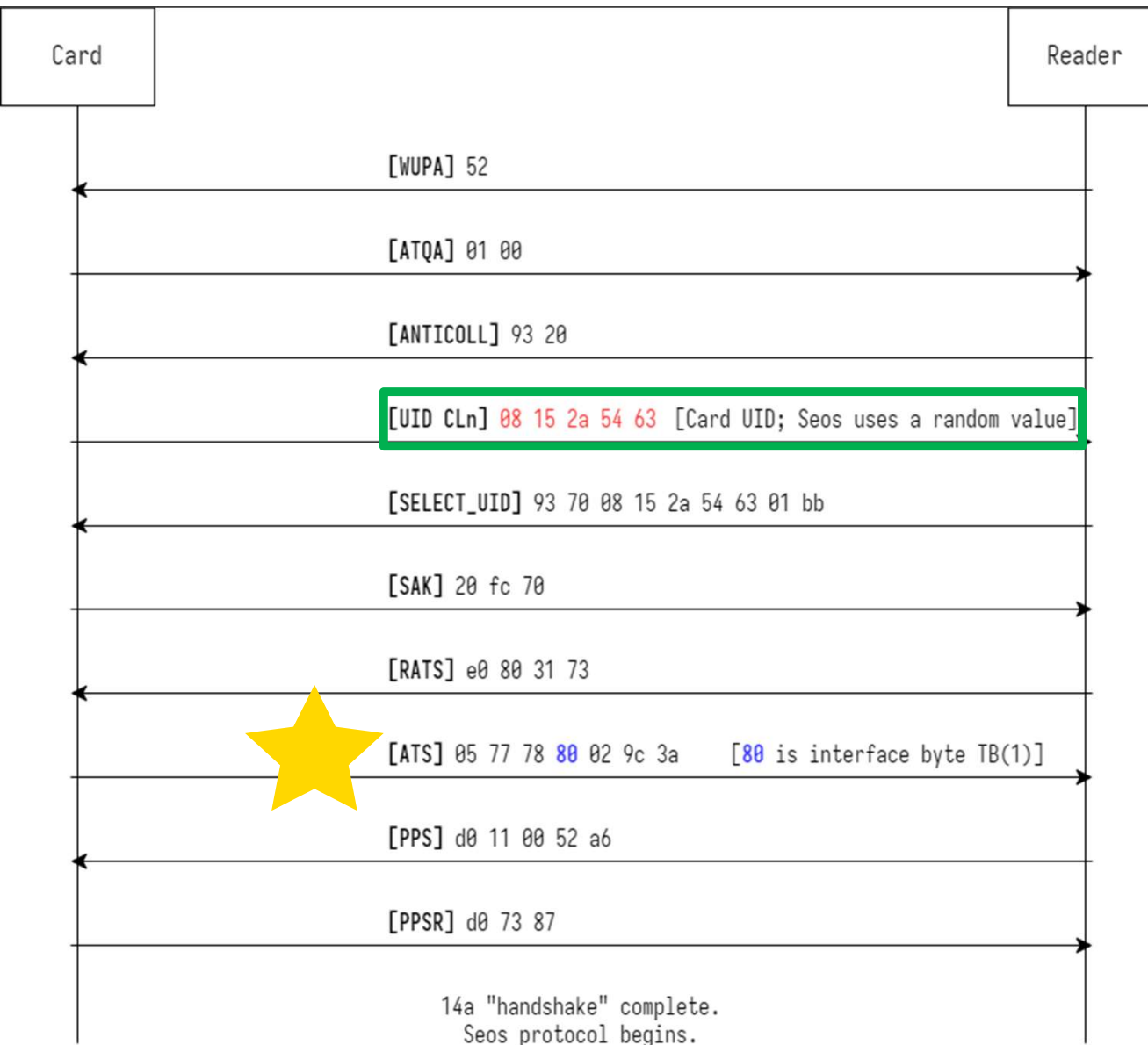
Sam Haskins, 2023-07-26T15:55:12.650

Methodology

- All the messages are generated by a real card and reader—so they're guaranteed to be correct!
- The **only way** readers can detect our attack is by detecting timing variations
 - RTT from Vegas – Ottawa is longer than RTT over $\approx$ an inch
- Can the readers support longer than normal timings?
- Yes...there's a few mechanisms
 - Let's explore one

ISO 14443-4 Type A

- All high-frequency (13.56 MHz) access control protocols we've talked about so far are built on top of ISO 14443-4 Type A (henceforth "14a")
- Analogous to how HTTP is built on top of TCP
- Provides a transport for higher level protocol messages
- Before any application layer data is exchanged, the card and reader perform a standard 14a "handshake"
 - Not encrypted or authenticated at all (just a 16-bit CRC on some parts)
 - So we can mess with it!
- Let's have a look...



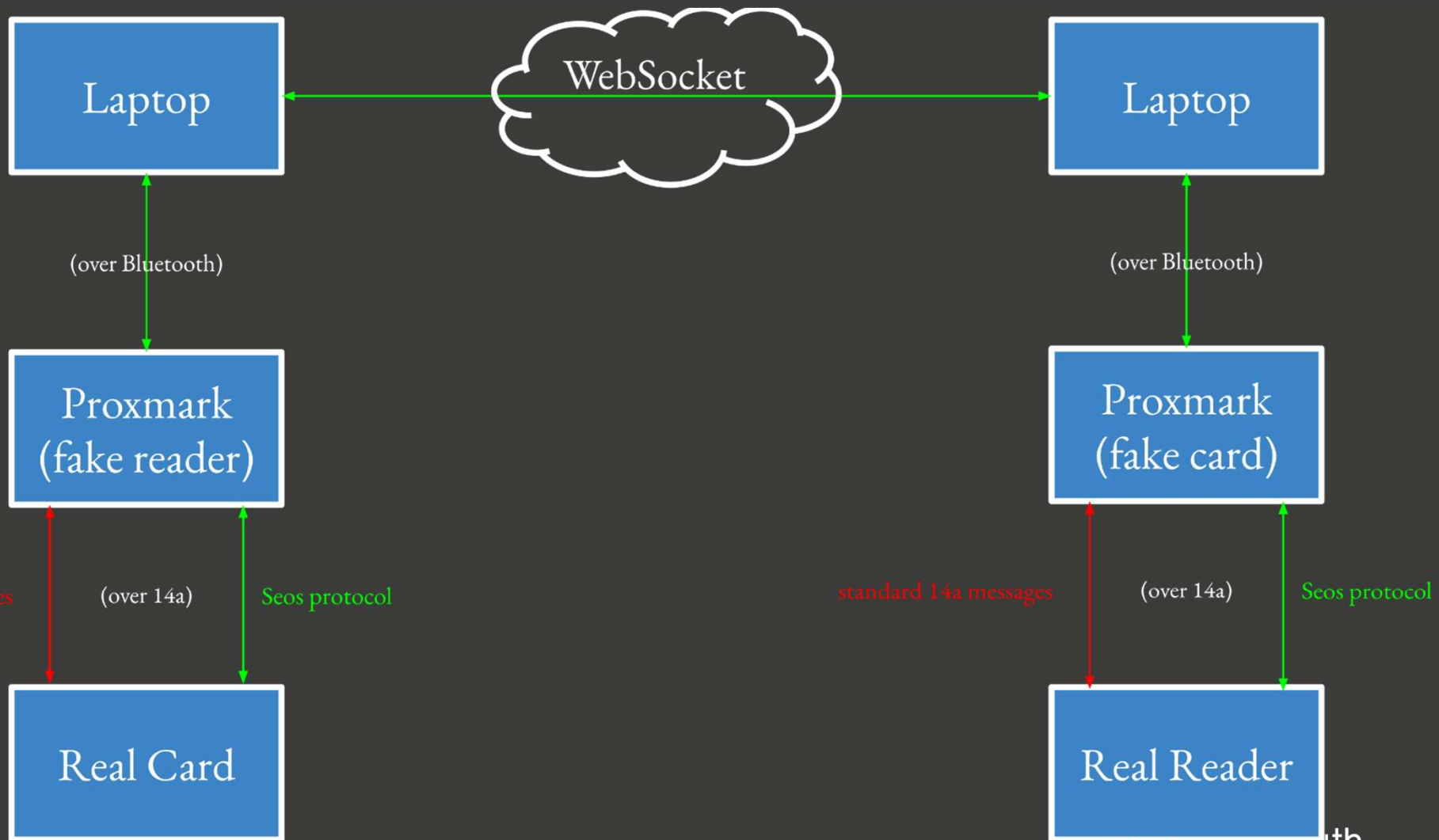
- ATS is “Answer to Select” (RATS is “Request Answer to Select”)
- Interface byte TB(1) codes the Frame Waiting time Integer (FWI) in its high nybble
- The FWI defines the Frame Waiting Time (FWT), like so:

$$(FWI \in \mathbb{Z}^*) \wedge (0 \leq FWI \leq 14)$$

$$FWT = \left(256 \cdot \frac{16}{f_c} \right) \cdot 2^{FWI}$$

The Seos Protocol

75022538	75045738	Rdr	0a 00 00 a4 04 00 0a a0 00 00 04 40 00 01 01 00 01 00		
			[0m 6a 2c		ok
75056638	75079806	Tag	0a 00 6f 0c 84 0a a0 00 00 04 40 00 01 01 00 01 90 00		ok
			[0m 6f a4		
81134830	81168398	Rdr	0b 00 80 a5 04 00 13 06 11 2b 06 01 04 01 81 e4 38 01		
			01 07 01 13 01 01 02 02 00 6b 13		ok
81221026	81221026	Tag	0b 00 c1 02 09 07 85 40 35 37 f7 91 6b cd ad d0 57 a1		
			1d 09 b1 91 36 aa 9c e2 a6 e3 6c a6 04 ec 39 cf 01 6a		
			3b 03 ee e3 81 c1 07 25 6e e3 8a cc 9f c0 5a 9c e0 96		
			5c ae db 6a b1 74 09 1f 0f 84 4b 6f 59 da 5c 90 ae 40		
			8e 08 30 f2 e0 27 25 31 ba 6a 90 00 25 bf		ok
87175828	87192052	Rdr	0a 00 00 87 00 01 04 7c 01 81 00 00 9c 8d		ok
87219528	87240392	Tag	0a 00 7c 0a 81 08 f6 83 b6 01 8d 11 85 ce 90 00 6f 02		ok
93220244	93282612	Rdr	0b 00 00 87 00 01 2c 7c 21 81 73 c4 a5 7d 21 11 08 aa		
			8a 63 cc e0 51 3b ae b0 87 b5 5d 04 9c 5d 2a e6 c2 a1		
			a4 3f de e3 85 6c a7 98 e8 04 18 0c 11 c9 99 00 03 dc		ok
93334984	93392648	Tag	0b 00 7c 2a 82 28 ce c3 0e e4 7d f1 9e 21 4f 0c 2f 29		
			f5 94 3c 69 d2 d5 7e cc bf 18 5a c be 07 fc 79 b4 8d		
			0d 11 7c 4d 35 1f 14 71 89 e5 90 00 f8 c1		ok
99598154	99644330	Rdr	0a 00 0c cb 3f ff 1e 85 10 93 73 17 06 87 2c 11 cc 19		
			8c c4 d3 7b 66 fa 00 97 00 8e 08 63 ab 96 52 36 d7 60		
			62 00 9b 06		ok
99683198	99683198	Tag	0a 00 85 40 b4 40 68 bf d8 1c 27 33 2f 1e 53 19 43 04		
			48 e0 94 48 01 48 0d 95 63 13 41 52 3a 0a e3 d4 96 91		
			c5 5e 7a f8 e4 b4 39 ee 68 68 70 20 6e 5a 6e 8c cf bc		
			08 f0 7e 04 84 6f a8 a0 8e bd 6c dc 91 47 99 02 90 00		
			8e 08 e6 34 42 65 42 04 f0 3f 90 00 0f ec		ok



Takeaway

- By manipulating the FWI, we can make the reader wait up to ≈ 4949 milliseconds for a reply
- This is one technique we can use to bypass the 14a round-trip time check
- There is another...

Waiting Time eXtension (WTX)

- Per the 14a spec, the card can request more time from the reader by sending a Waiting Time eXtension (WTX) message
- This extends the frame waiting time for one message only, but can be repeated as much as needed
- Coded as “F2 0B” to request the maximum amount of time allowed per spec
- Has been used for other relay attacks (i.e., Credit Cards, Tesla relay)
- Was less reliable with the HID readers we tested

Original Design

Standing on the shoulders of giants...

- Implemented as an extension to the hf_relay Proxmark standalone mode originally written by Salvador Mendoza
 - Some changes to allow relaying the Seos protocol + adding the long-range Internet component
- Strongly coupled with the BlueShark Bluetooth add-on
- Messages were conveyed Proxmark <-> Laptop via Bluetooth before being sent over IP
- We had a lot of success with this design!
 - Highlight: unlocking a door in Ottawa with a card in Florida
- However, there were some reliability issues...

Problem 1 – Battery Woes

- The BlueShark BT addon comes with an integrated rechargeable battery
 - More convenient for IRL use than running a cable up your sleeve!
- However...
- The ability of the fake reader Proxmark to talk to the card was *really* sensitive to the battery level in our testing
 - Too high *or* too low...we would get a bad read
- We don't really know why this is the case
- This proved frustrating...



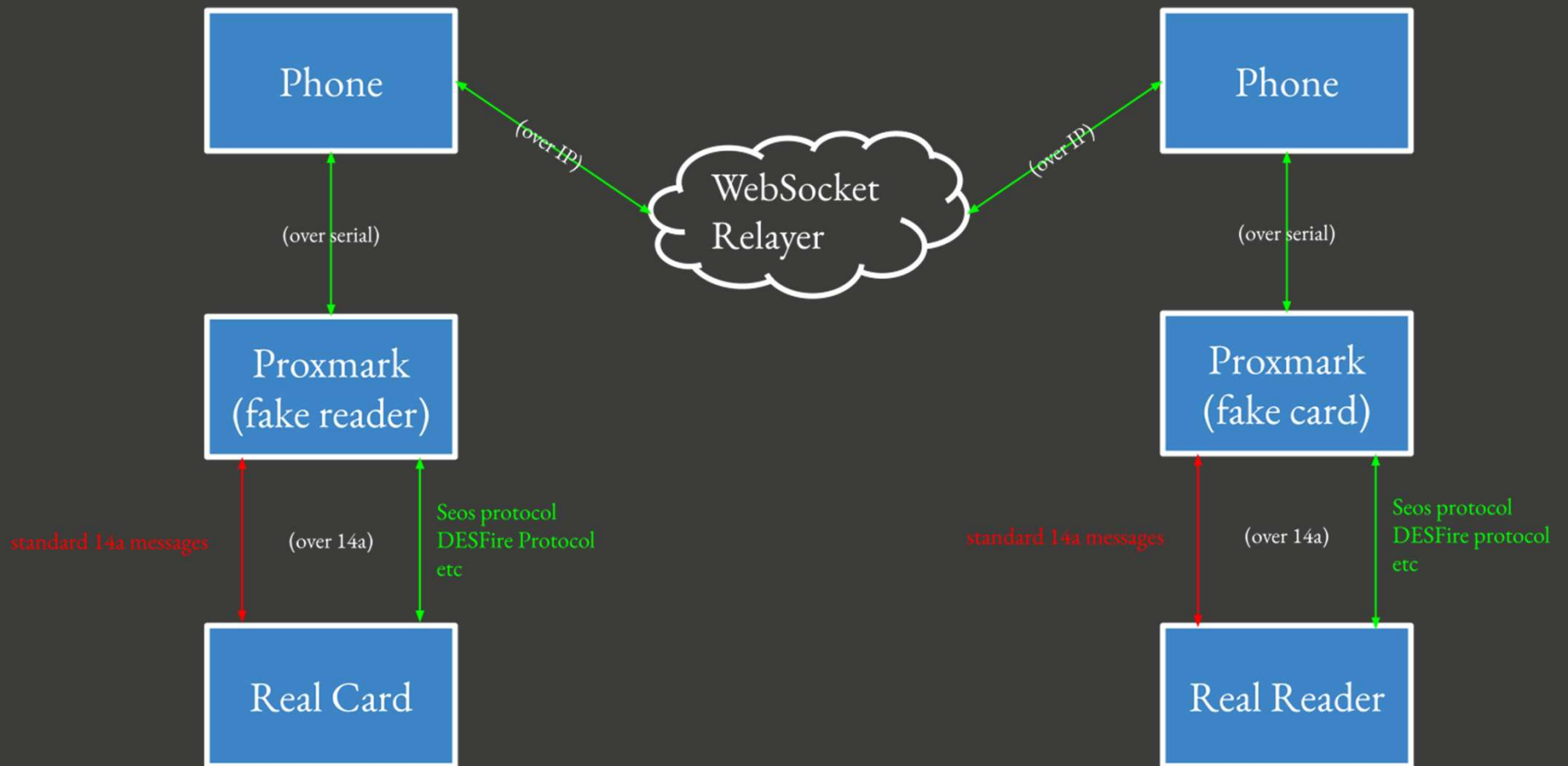
Problem 2 – Latency

- Real cards are designed under the assumption that the reader will respond within at most a few milliseconds (and typically much faster)
- We blow this assumption out of the water by several orders of magnitude...
- The card sometimes “forgets” that it’s in the middle of the protocol, and this happens increasingly often as the latency increases
 - Different cards could be more resilient (most of our observations were with Seos)
- Between this and the battery issues, our initial design was not reliable
 - Usable, if not reliable, within the same city
 - Hard to make it work over longer distances

Our Revised Design

© 2023 Loudmouth Security | COMPANY CONFIDENTIAL





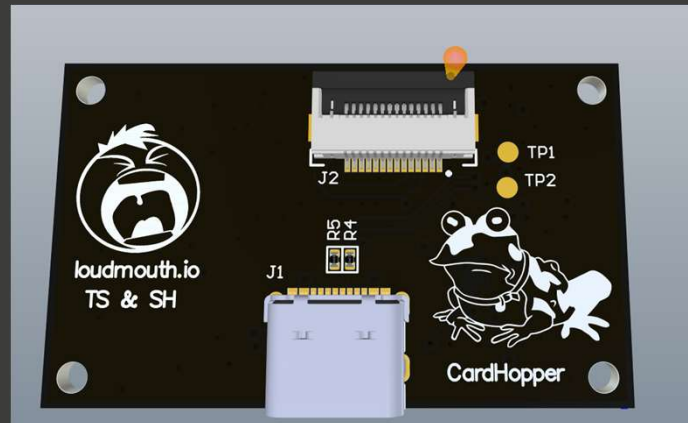
Software – hf_cardhopper

- Standalone module for Iceman's Proxmark 3 firmware
- Inspired by Salvador Mendoza's hf_relay, but doesn't share any code
- Tricks readers into using a longer Frame Waiting Time (as described earlier)
- Can relay any ISO 14443-4 Type A-based protocol
- Support for relaying the UID CLn and ATS (if not quite in real-time)
 - Operator will put fake card on real reader *after* fake reader reads real card
- Works with BlueShark and...
- ...our custom hardware!



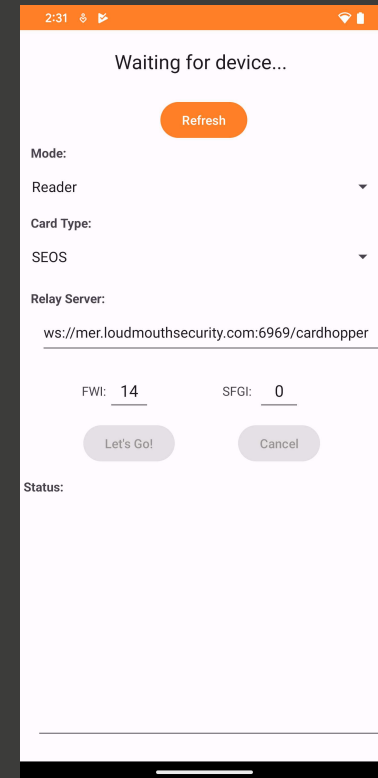
Hardware – CardHopper Board

- Replaced the USART ↔ Bluetooth bridge with a USART ↔ USB bridge
- Similar in design to Shikra, but with ribbon adapter for integration with Proxmark
 - Maybe even the *right* ribbon cable...
- USB-C output for connecting to phone (or computer)



Android App

- Custom Android App to bridge the communication between FTDI chip and relay server
- Support for Card and Reader modes of operation
- Support SEOS and DESFire EV1 cards
- Can adjust FWI values for your specific target
- Handles hardware reset in case of failures
- Function over style 🧙



Results

→ Readers

- RPK40 921PTNNEK00000
- RP40 920NMNNEKMA001
- Signo 20NKS-00-000000
- Signo 40NKS-01-000000
- Signo 40NKS-02-000000

Results

→ Credential technologies

- Seos
- DESFire EV1
- DESFire EV2
- DESFire EV3

NXP – Patent EP2940882A1

“Proximity check for communication devices”

→ Adds information about how long the card should take to respond to the protected part of the communication

→ Distances

- 12 feet in our lab
- Across the city
- Across *countries*
- Vegas – Ottawa
- Vegas – Ottawa *on stage* (much harder!) ???
- Further ???

Demo

insert joke about demo gods here



What credential technology is currently being supported?

- (32%) 125kHz low-frequency prox
- (35%) Magnetic stripe
- (26%) iCLASS
- (28%) QR code
- (18%) MIFARE Classic
- (15%) MIFARE DESFire EV1/EV2/EV3
- (10%) Seos

- Seos – 2012
- EV1 – 2006
- EV2 – 2016
- EV3 – 2020

HID Global's Response

© 2023 Loudmouth Security | COMPANY CONFIDENTIAL



Responsible Disclosure through BugCrowd

- Disclosed December 9th, 2022
- Triaged on Jan 17th, 2023
- Final response on Mar 10th, 2023
- *“your recommendation to reject authentication attempts that exceed a specified time limit would make the readers out of compliance with the ISO 14443 specifications. Further, it impacts our customer needs to support backward compatibility, so it is not a modification we are planning to make at this time”*
- *“the majority of our end users do not see relay attacks as a viable threat”*
- *“our end users that are concerned about relay attacks will typically deploy a second factor of authentication, such as a PIN or biometrics. Some also use our mobile credentials, which can be set only to transmit when the app is in the foreground.”*

Okay, all of you need to enter a six-digit PIN now...

(Ft. Meade, Maryland)



How can you get a CardHopper?

- Come play in the Embedded Village CTF
part of the prize package for the top 3 teams includes a CardHopper board!
- You wanna collaborate on RFID research?
Do you have any cards, readers, ideas that we can work together on?
Come see us at Embedded Village and we'll give you a board.



Questions?

we may or may not have answers